

Vulnerability Assessment Report

August 12, 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2026 to August 2026. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The purpose of this vulnerability assessment is to evaluate the security risks associated with the company's publicly accessible database server. The database contains information that is important to the company's operations and must be protected from unauthorized access, modification, or theft. Because the server has been publicly accessible since the company's launch, it presents significant risks to the confidentiality, integrity, and availability of business data. This assessment identifies key threats, evaluates their potential impact, and recommends security controls to reduce the organization's exposure to these risks.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>Hacker</i>	<i>Obtain sensitive information via exfiltration</i>	3	3	9
<i>Employee</i>	<i>Alter/Delete critical information</i>	2	3	6
<i>Customer</i>	<i>Perform reconnaissance and surveillance of organization</i>	1	3	3

Note: Risk is calculated using the formula: Likelihood X Severity = Risk

Risk Score Calculations:

- **Hacker:** *Likelihood (3) X Severity (3) = 9 (High Risk)*
- **Employee:** *Likelihood (2) X Severity (3) = 6 (Moderate-High Risk)*
- **Customer:** *Likelihood (1) X Severity (3) = 3 (Moderate Risk)*

Approach

I chose a qualitative assessment to focus on the biggest operational threats to our publicly exposed database. Hackers are by far our highest priority threat (Risk: 9) because leaving a server completely open on the internet for three years makes an exfiltration attempt almost guaranteed (Likelihood: 3), and losing that data would be catastrophic for the business (Severity: 3). Employees represent a moderate risk (Risk: 6) because their daily access to run queries means an accidental oversight or misuse could easily disrupt our core operations. Finally, while customer-driven data deletion is far less likely (Likelihood: 1), it still carries a high impact if someone manages to pull it off, giving it a Risk score of 3.

Remediation Strategy

First and foremost, we need to take the database off the public internet and pull it behind a secure VPN or firewall that mandates Multi-Factor Authentication (MFA) for access. From there, we should apply the Principle of Least Privilege using the AAA framework so remote employees and customers only have access to the exact data they need to do their jobs. To protect against exfiltration, we ought to set up Public Key Infrastructure (PKI) to encrypt data in transit and enable comprehensive log auditing. Layering these Defense in Depth controls will effectively close our public vulnerability and protect the business from future compromise.